

**SHARING KNOWLEDGE.
TOGETHER.**

**WORKPLACE
NINJA**

**SUMMIT
SUMMIT
SUMMIT
SUMMIT
SUMMIT**



**SHARING KNOWLEDGE.
TOGETHER.**

**WORKPLACE
NINJA**

**SUMMIT
SUMMIT
SUMMIT
SUMMIT
SUMMIT**



Hi 
Ninjas!

SUMMIT
SUMMIT
SUMMIT



Hi 
Ninjas!

SUMMIT
SUMMIT
SUMMIT
SUMMIT
SUMMIT



What's Next After Phishing-Resistant MFA?

Securing the Post-Authentication Attack Surface

Erik Loef & Kenneth van Surksum

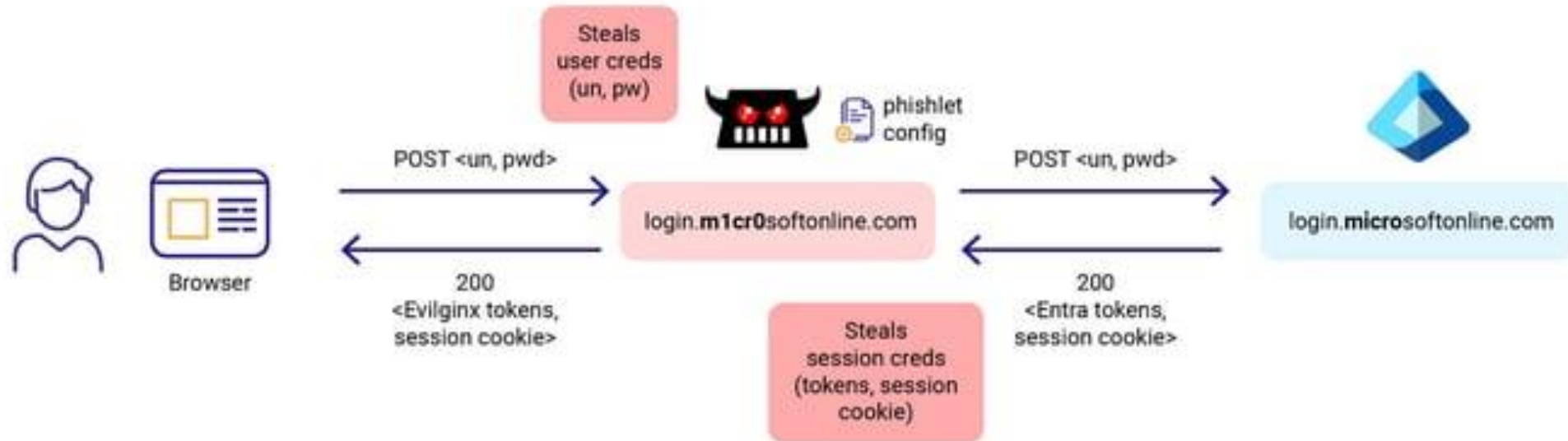


Adversary in The Middle (AiTM)

Quick Recap



AITM



Phishing “resistant” authentication

- Resistant to primarily **credential phishing** on fake login pages
- Phishing resistant methods:
 - FIDO keys: use URL as part of authentication flow.
 - Windows Hello: authentication is performed by Windows via PRT, not controllable by user.
 - Passkeys: act as FIDO keys
- Not resistant against:
 - Device code phishing
 - OAuth consent phishing
 - Downgrading to non phishing resistant method
 - Malware phishing



previder

CTO of ODIN GROUP
PREVIDER | CLOUDWISE | VICTA

e.loef@odin-groep.nl



Microsoft®
Most Valuable
Professional

Kenneth van Surksum

Modern Workplace Consultant | Secure At Work

kenneth@secureatwork.nl

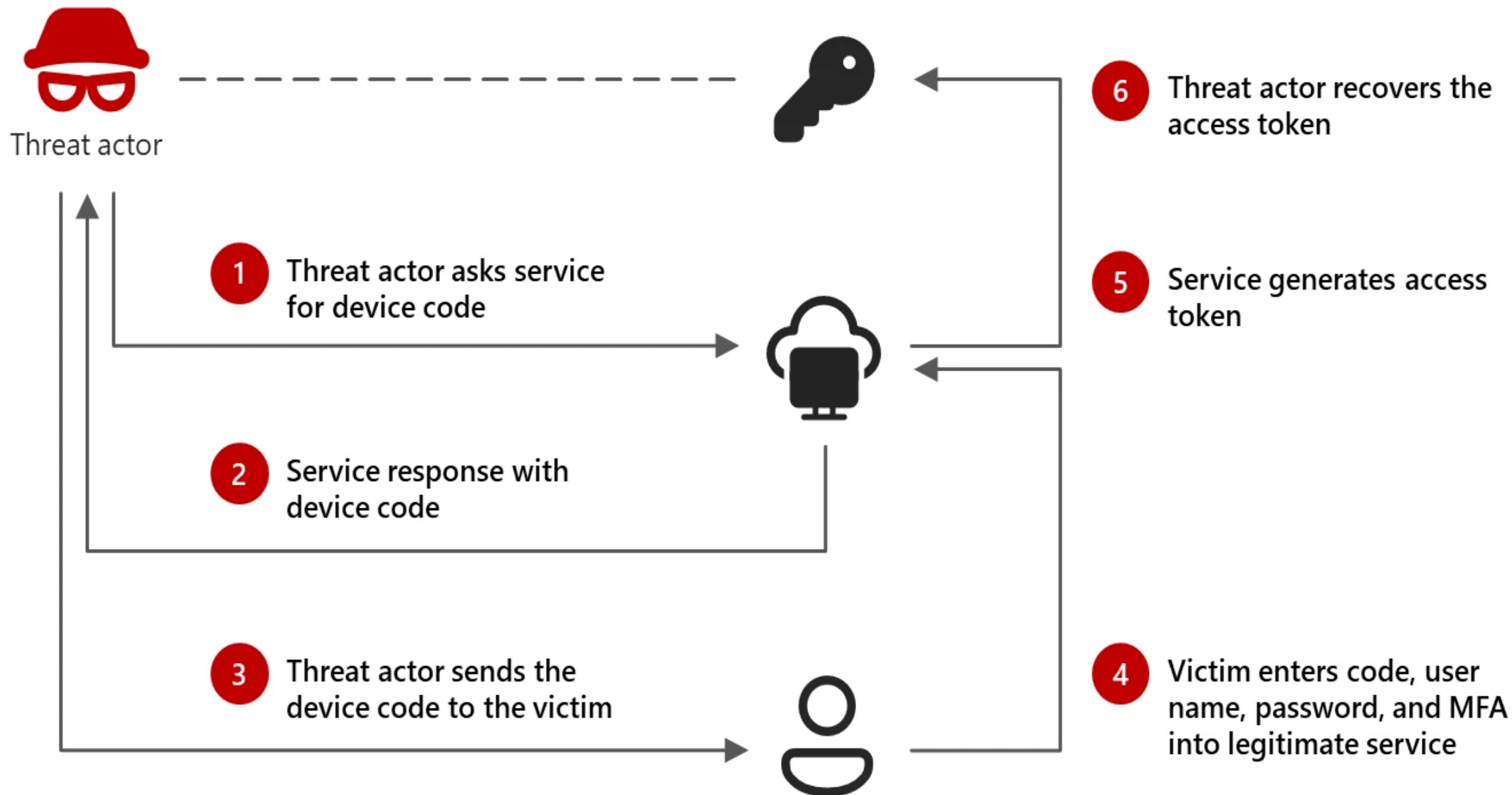


Device Code Flow Attack

with phishing resistant
methods

GraphSpy





Devicecode phishing

Microsoft Teams [Need help?](#)

[Join the meeting](#)

Meeting : **685 318 885 965**

ID:CMUZKJSCW

For organizers: [Meeting options](#)



Security

Products ▾

Solutions ▾

Pricing

Services

Part

[Blog home](#) > Passkey-themed social engineering leads to identity and cloud compromise

[Research](#) • September 9 • 19 min read

Passkey-themed social engineering leads to identity and cloud compromise

By [Microsoft Security Research](#), [Krithika Ramakrishnan](#), [Bharat Vaghela](#), [Vaibhav Deshmukh](#), [Subhajit Ghosh](#), [Anusha Chakraborty](#), [Akash Chaudhuri](#), [Victor Chingtham](#) and [Ivan Macalintal](#)

DeviceCode Flow CA options

Home > c4a8korriban | Security > Security | Conditional Access > Conditional Access | Policies >

Block Device Code Flow ...

Conditional Access policy

Delete

View policy information

All cloud apps

Conditions ⓘ
1 condition selected

Access controls

Grant ⓘ
Block access

Session ⓘ
0 controls selected

Not configured

Client apps ⓘ
Not configured

Filter for devices ⓘ
Not configured

Authentication flows ⓘ
Device code flow

Enable policy

Report-only On Off

Save

Authentication flows ×

Control how your organization uses certain authentication and authorization protocols and grants

Configure ⓘ
☒ Yes

Transfer methods

☒ Device code flow

☐ Authentication transfer

Save

PRT Stealing or PASS-THE-PASSKEY or ClickFix

with phishing resistant method
Windows Hello for Business



About::ClickFix

- Recent Example “gemeente EPE”

Data Breach at Gemeente Epe (Netherlands) on March 14, 2026

epe.nl

Open

On March 14, 2026, Gemeente Epe experienced a significant data breach affecting approximately 800 gigabytes of sensitive citizen information. The breach was conducted by professionals via a ClickFix phishing attack that compromised internal work drives. While the systems have been secured, officials are investigating the full extent of the leak and advising residents to remain vigilant against potential data misuse.



Complete these

Verification steps

About this page

Our systems are currently down due to a network issue. This page is for informational requests, and you can check back later.

Time: 2025-01-10 10:00:00
URL: file:///C:/Users/.../...

To prove you are not robot, please:

1. Press **Windows Key**  + **R**.
2. In the verification window, press **Ctrl + V**.
3. Press **Enter** on your keyboard to finish

Perform the steps above to finish verification

VERIFY

Passkey is becoming the default



← → ↻ 🔒 www.microsoft.com/en-us/security/blog/2026/07/13/microsoft-entra-id-security-updates-passkeys-are-the-default-authentication-method-in-entra-id/ 📄 📌 🗑️ ⭐

Microsoft | Security Products ▾ Solutions ▾ Pricing Services Partners Why Microsoft Security Resources ▾ Contact Sales More ▾ All Microsoft ▾ Search 🔍 Light 🌙

🏠 [Blog home](#) > Microsoft Entra ID security updates: Passkeys are the default authentication method in Entra ID 🔍 Search the blog

[News](#) • July 13 • 5 min read

Microsoft Entra ID security updates: Passkeys are the default authentication method in Entra ID

By [Nadim Abdo](#), Corporate Vice President, Identity and Network Access Engineering, Microsoft

Listen to this post

🔊 0:00 / 0:00 1X

🌈 Powered by Microsoft Copilot

A woman with dark hair tied back is sitting at a desk, looking at a laptop. She is also holding a smartphone in her left hand, which is displaying a blue screen. The background is blurred, showing an office or public space.

Secure At Work

Contoso Ltd

Entra ID Authentication Assessment - IST versus SOLL

Generated 2026-09-02 11:29:4331 checks18 findings openRead-only: no tenant changes made

Tenant: Contoso Ltd (aaaaaaaa-bbbb-cccc-dddd-eeeeeeeeeeee)

Assessed: 2026-09-02 11:29:42

Overview

Findings & Roadmap

User Journeys

Policy Inventory

Reading This Report

SOLL baseline: Hybrid AD, Passwords Still Required [auto-detected from tenant profile (Hybrid)]SOLL = target state for this customer · IST = what was actually observed in the tenant

Upcoming Microsoft Deadlines

Hand-maintained, sourced list of known Microsoft-driven Entra rollout dates relevant to the checks above - not tenant-specific findings. Verify against the linked source before treating a date as final.

Register Security Information CA Policies Extend To WHFB/macOS Platform SSO Registration

2026-07-06 · CA004

58 day(s) ago

Before this date, Conditional Access policies targeting the 'Register security information' user action did NOT evaluate during Windows Hello for Business or macOS Platform SSO credential registration - MFA was still required by default for those flows, but any stricter Grant controls (authentication strength, trusted locations, a TAP escape) on such a policy weren't enforced there. From this date they are. Widens CA004's blast radius: a policy that excludes Temporary Access Pass from its authentication strength now also blocks WHFB/macOS Platform SSO registration for TAP-only users, not just the combined registration experience - worth reviewing any Register-security-information-scoped policy if this wasn't already accounted for.

Source

Automatic Passkey Enablement For SMS/Voice Users

2026-09-01 · AUTH006AUTH002AUTH003

1 day(s) ago

2 user(s) impacted (users with a phone-based method (SMS/Voice) still registered (upper-bound proxy for tenant-wide policy scope - Graph doesn't expose per-user AMP-scope evaluation directly, only what's registered))

Microsoft auto-enables passkeys and flips the registration campaign to 'Microsoft managed' (targeting passkeys) for every user currently enabled for SMS or Voice in the authentication methods policy - based on policy scope, not on what else they have registered. A user who already has a passkey/WHFB/other phishing-resistant method registered is not exempt from this: Microsoft's own docs note such users 'may still receive prompts to register passkeys on eligible devices' (the per-device/browser nudge-suppression logic only skips devices where a qualifying local passkey is already present). Not blocking, and AUTH006's opt-out (passkeyDynamicMigration) defers it. See AUTH006.

Source

Customer-Managed Telecom Providers Become Reviewable (Microsoft Security Store)

2026-09-18 · AUTH002AUTH003

16 day(s) left

2 user(s) impacted (users with a phone-based method (SMS/Voice) still registered - only the regulated/operational subset of these needs a telecom provider at all)

Microsoft publishes the telecom providers and related information in the Microsoft Security Store, so tenants with a genuine regulatory or operational need for an SMS/Voice channel can evaluate which option meets their regional and compliance requirements. This is an OPENING, not a deadline: nothing is required of anyone on this date, and it only matters to the subset of tenants that cannot move a given user segment to a phishing-resistant method. Everyone else should be treating passkeys as the migration path and can ignore this row. Verified 2026-08-09 against the Source URL: 'Beginning September 18th, 2026, review the telecom providers and related information available through the Microsoft Security Store to evaluate which option best meets your regional and compliance requirements.'

Source

System-Preferred Authentication (Microsoft Managed) Gradual Rollout Completes

2026-09-30 ·

28 day(s) left

Not a hard cutover date. Date corrected 2026-08-31 from an earlier recorded value of 2026-08-31 ('through August 2026') to late September 2026, per Message Center MC1411574: 'beginning late June 2026 and expected to complete by late September 2026 - updated from the original late July deadline' (message last updated 2026-08-24). Shown here as the last day of that window as an upper-bound estimate. Source discrepancy worth knowing: Microsoft's public concept-system-preferred-

SSPR Stops Accepting Directory-Sourced Contact Info

2026-10-05 · SSPR001

33 day(s) left

3 user(s) impacted (SSPR-enabled users not yet SSPR-registered (upper-bound proxy - Graph doesn't expose whether a registered method is directory-sourced or explicit))

SSPR will only accept explicitly registered authentication methods from this date. Directory-sourced attributes synced from on-premises AD (mobilePhone, businessPhone, otherMails) that were never explicitly registered stop working for SSPR verification. Date corrected from an earlier recorded value of 2026-09-07 - re-verified

Customer-Managed Telecom Providers Become Configurable

2026-10-30 · AUTH002AUTH003

58 day(s) left

2 user(s) impacted (users with a phone-based method (SMS/Voice) still registered - only the regulated/operational subset of these needs a telecom provider at all)

From this date a tenant that needs to keep SMS or voice can actually select and configure a telecom provider from the Microsoft Security Store, then stand up the carrier contract and pilot it. Note the wording carefully, because secondary write-ups have compressed this into 'organizations must configure their own telecom provider

Secure-At-Work/saw-authentication-assessment-toolkit: Read-only PowerShell toolkit that assesses Microsoft Entra ID authentication configuration against a documented target state, with gap analysis, risk scoring, and remediation guidance. Built by Secure At Work.

passkey



3x pass the “pass”key

- SpecterOps showed a Windows and Microsoft Entra ID chain that could impersonate privileged users while satisfying phishing-resistant multifactor authentication (MFA); that chain reused signed authentication material rather than stealing the authenticator's private key.
- Unit 42 showed attacks against [Google Password Manager in Chrome](#), including a path that recovers the private keys for a victim's synced passkeys.
- Independent researcher [Dirk-jan Mollema showed](#) that malware already running in a signed-in Windows session can use a hardware-bound Windows Hello for Business key without asking the user to unlock it again.

Endpoint Protection | BYOD??



Next to pass the passkey we already had:

Pass the PRT

Pass the Cookie

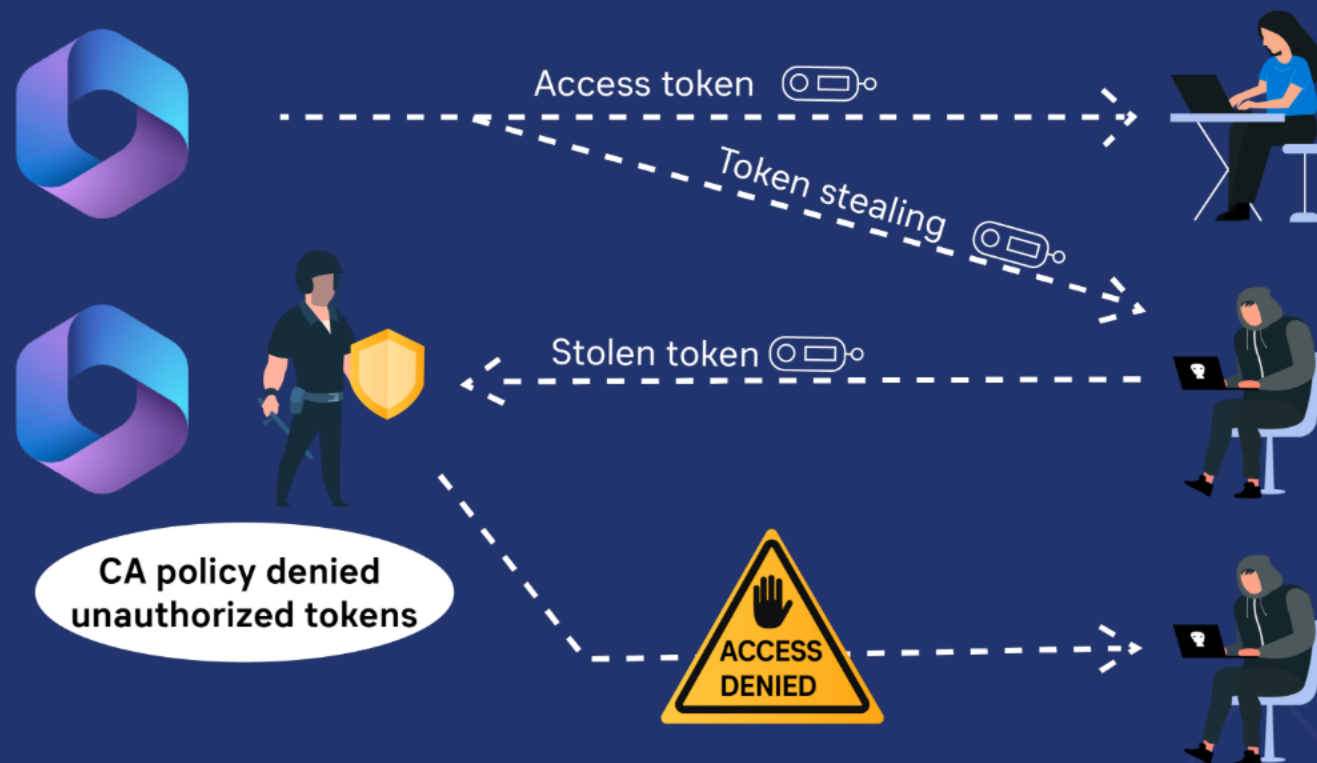
TOKEN PROTECTION

- demo
- configuration



Token Protection in Azure AD Conditional Access

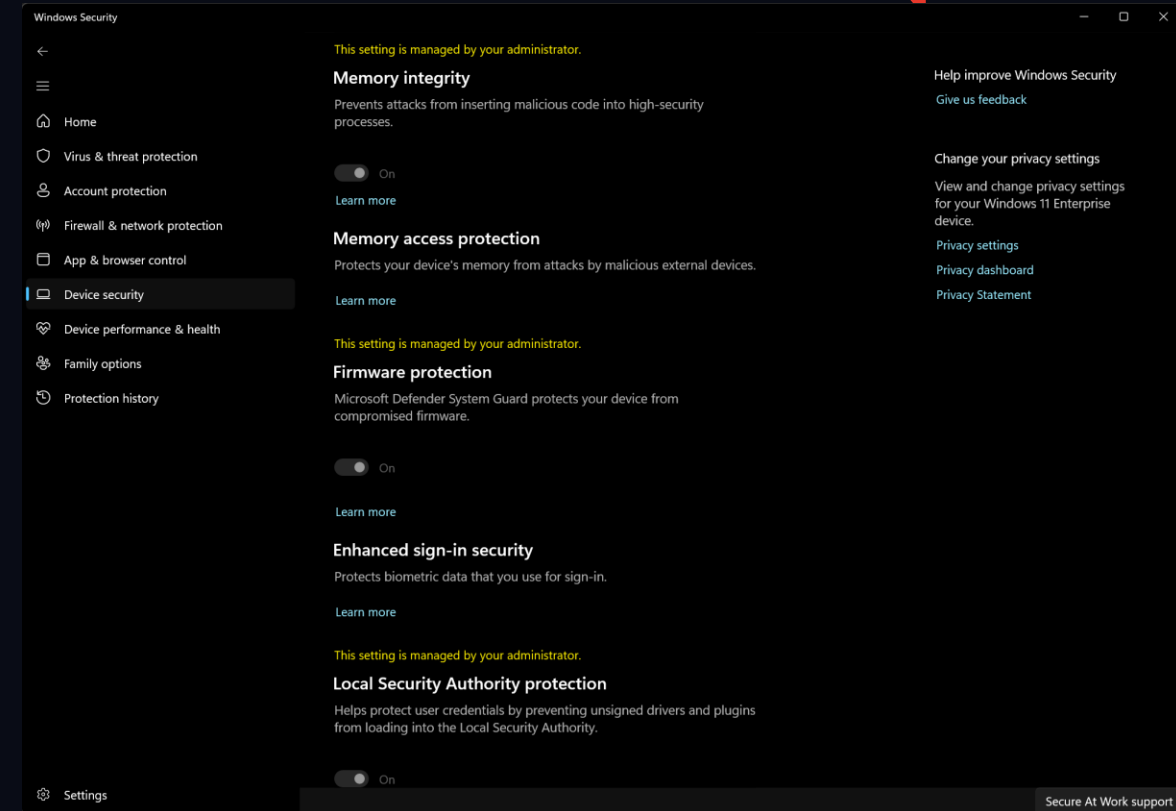
– A Savior to Control Token Phishing!



How to Protect Your Tokens



- **Enable Credential Guard** – isolate LSASS with Virtualization-Based Security (VBS)
- **Turn on LSA Protection** – run LSASS as a Protected Process (PPL)
- **Require TPM 2.0** – bind secrets (PRT, keys) to hardware & support measured boot
- **Use Windows Hello for Business / FIDO2** – replace passwords with hardware-backed keys
- **Enable RDP Credential Guard** – stop credential theft over remote sessions
- **Enforce HVCI (Memory Integrity)** – block unsigned kernel drivers & token-stealing rootkits
- **Deploy WDAC (App Control)** – allow only trusted code to run, block Mimikatz-like tools
- **Block Legacy Authentication** – remove protocols that expose reusable tokens (NTLM, basic auth)
- **Harden Browsers** – use Defender SmartScreen & Conditional Access to protect session cookies



AiTM downgrade attack



More information



- <https://youtu.be/LS-m7zgUMII>
- [Hook, Line and Sinker: Phishing Windows Hello for Business | by Yehuda Smirnov | Medium](#)
- <https://www.youtube.com/watch?v=UnudlFeHlrU>
- [How attackers are getting around phishing-resistant auth](#)

Consent Abuse



login.microsoftonline.com/common/SAS/ProcessAuth



Permissions requested

unverified

This application is not published by Microsoft or your organisation.

This app would like to:

- ✓ Sign you in and read your profile
- ✓ Maintain access to data you have given it access to

Accepting these permissions means that you allow this app to use your data as specified in their Terms of Service and Privacy Statement. **The publisher has not provided links to their Terms for you to review.** You can change these permissions at <https://myapps.microsoft.com>. [Show details](#)

Does this app look suspicious? [Report it here](#)

Cancel

Accept



Wrap Up



- Move to Phishing Resistant MFA, yesterday
- Review your CA policies after this movement (for the downgrade attack)
- Block the Device Code Flow
- Be very careful with BYOD scenario's (no security)
- App Consent and review apps with too much rights (App Governance)
- In the end you are never 100% secure

Thank You, Ninjas!



Halle 36.3
room check-in



Welcome on stage



Session

Speaker

#wpninjas

Welcome on stage

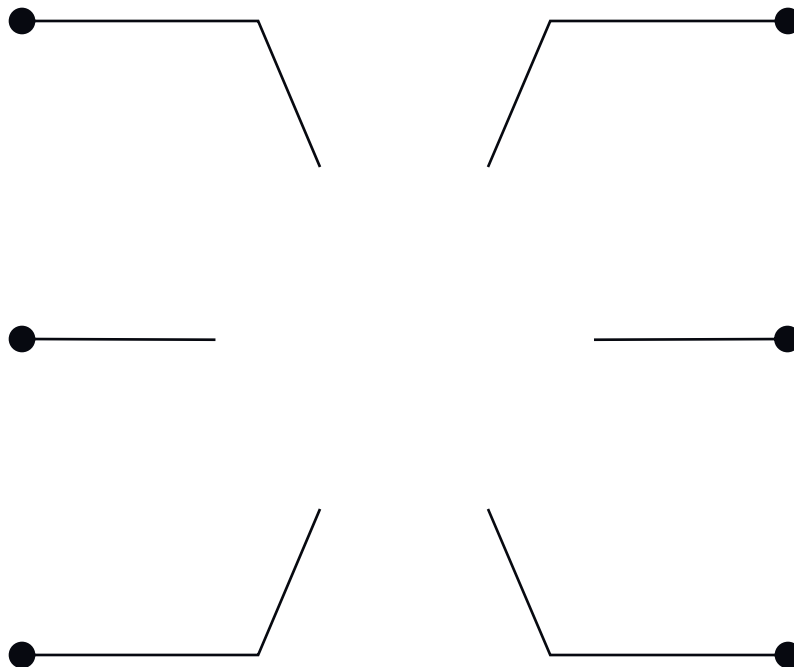


Session

Speaker

Speaker

#wpninjas



01

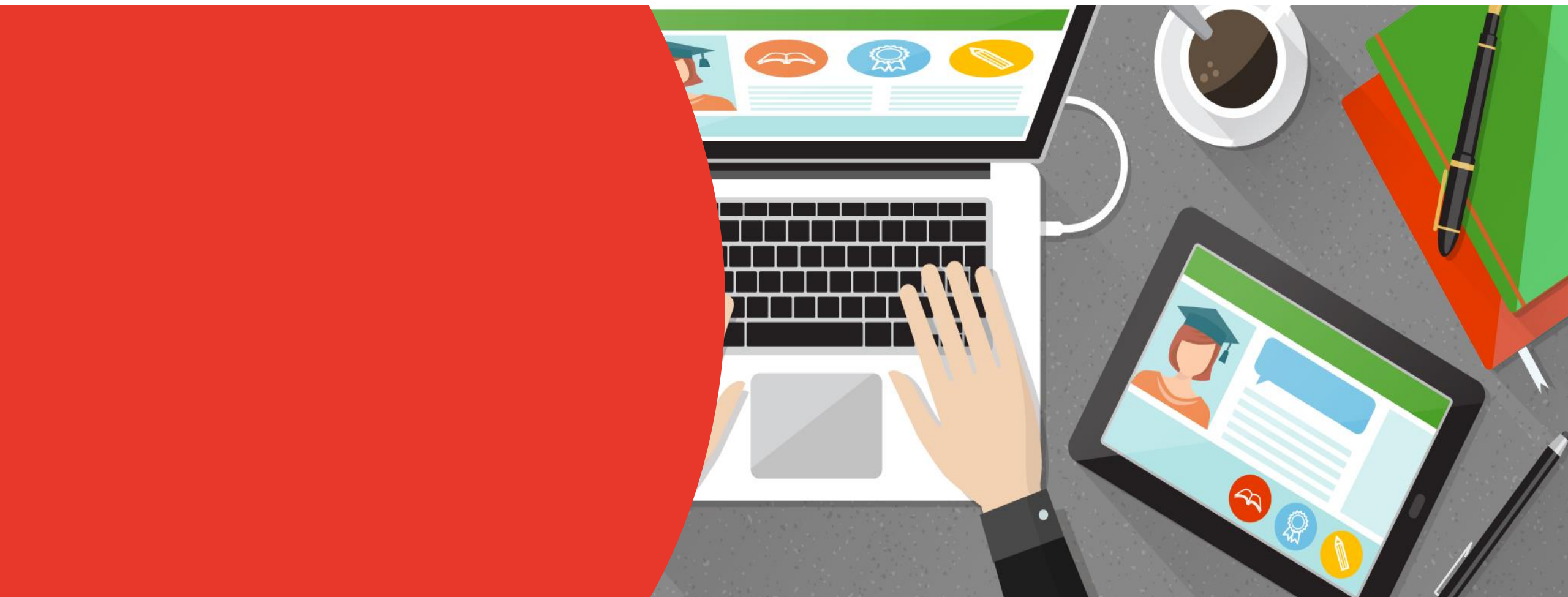
04

02

05

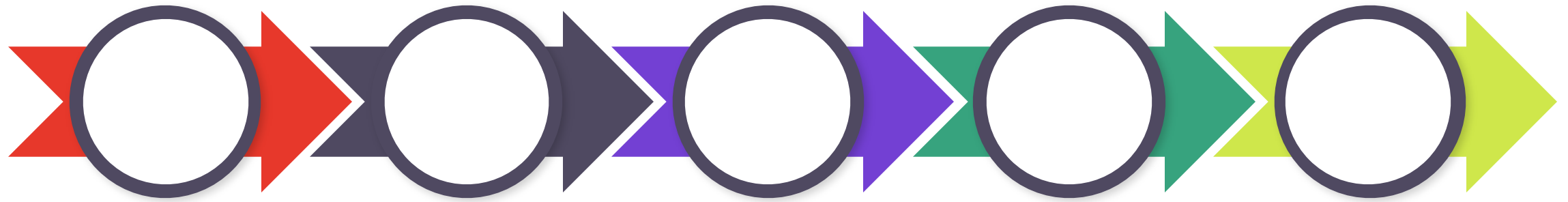
03

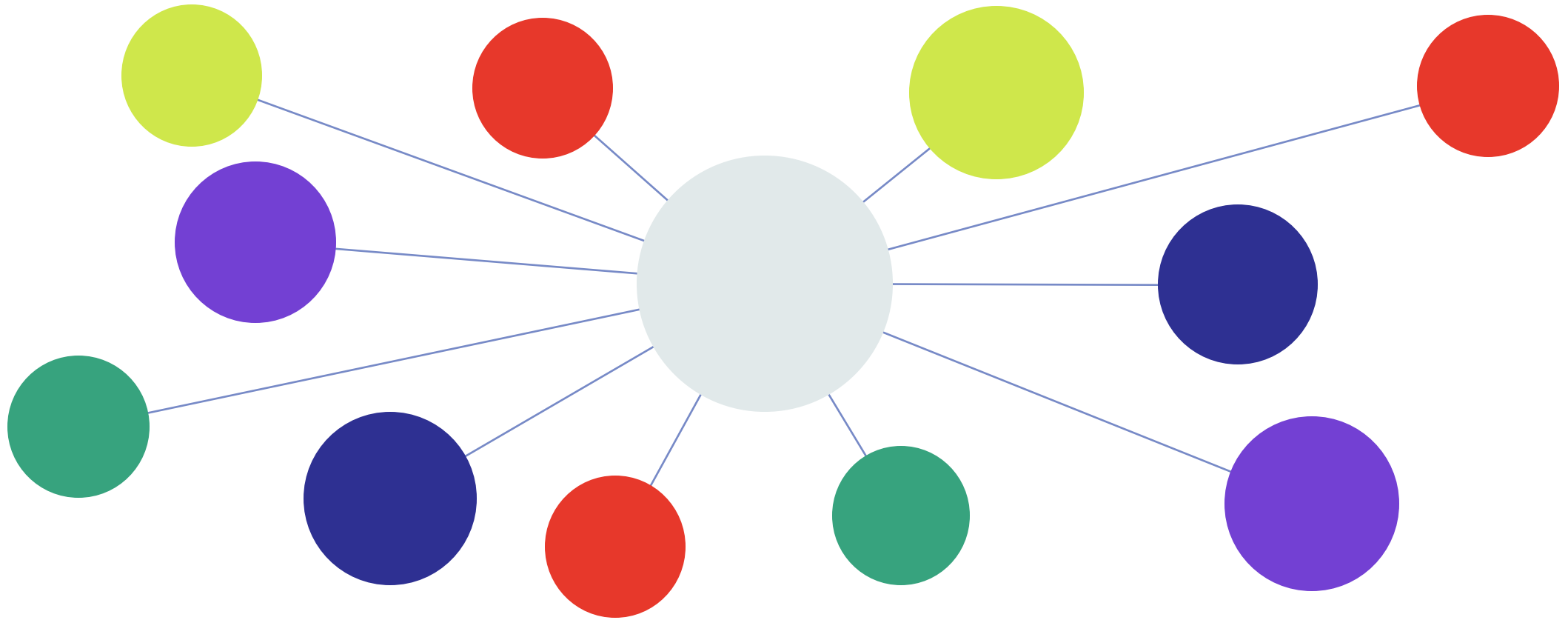
06





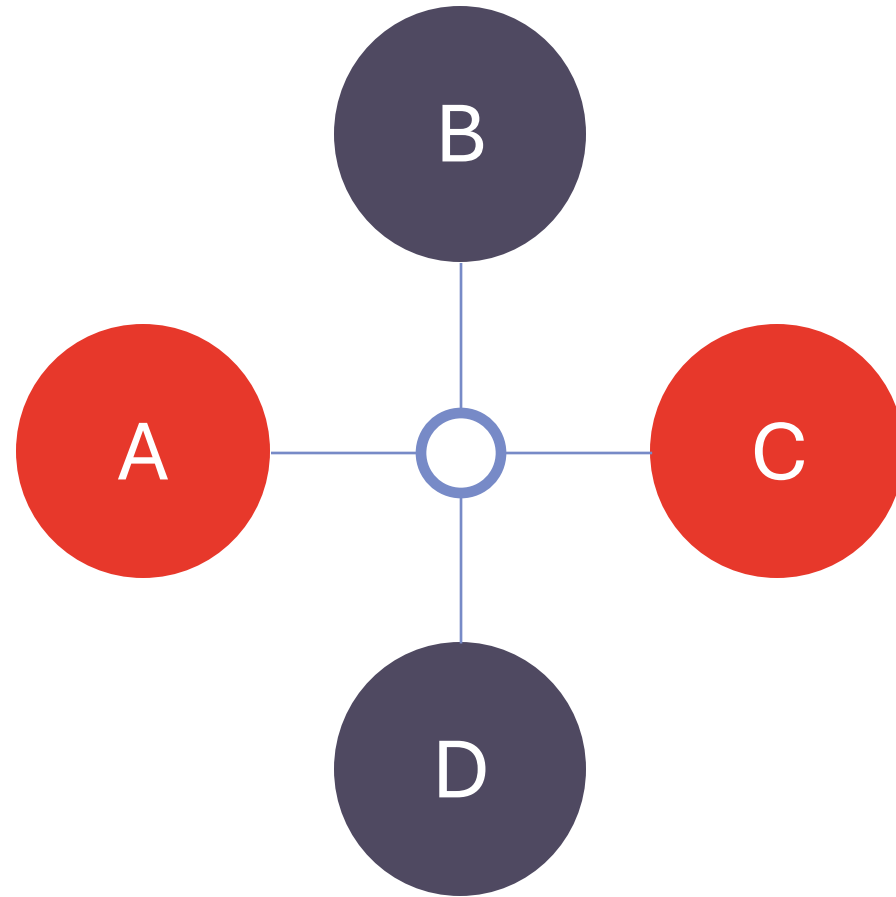






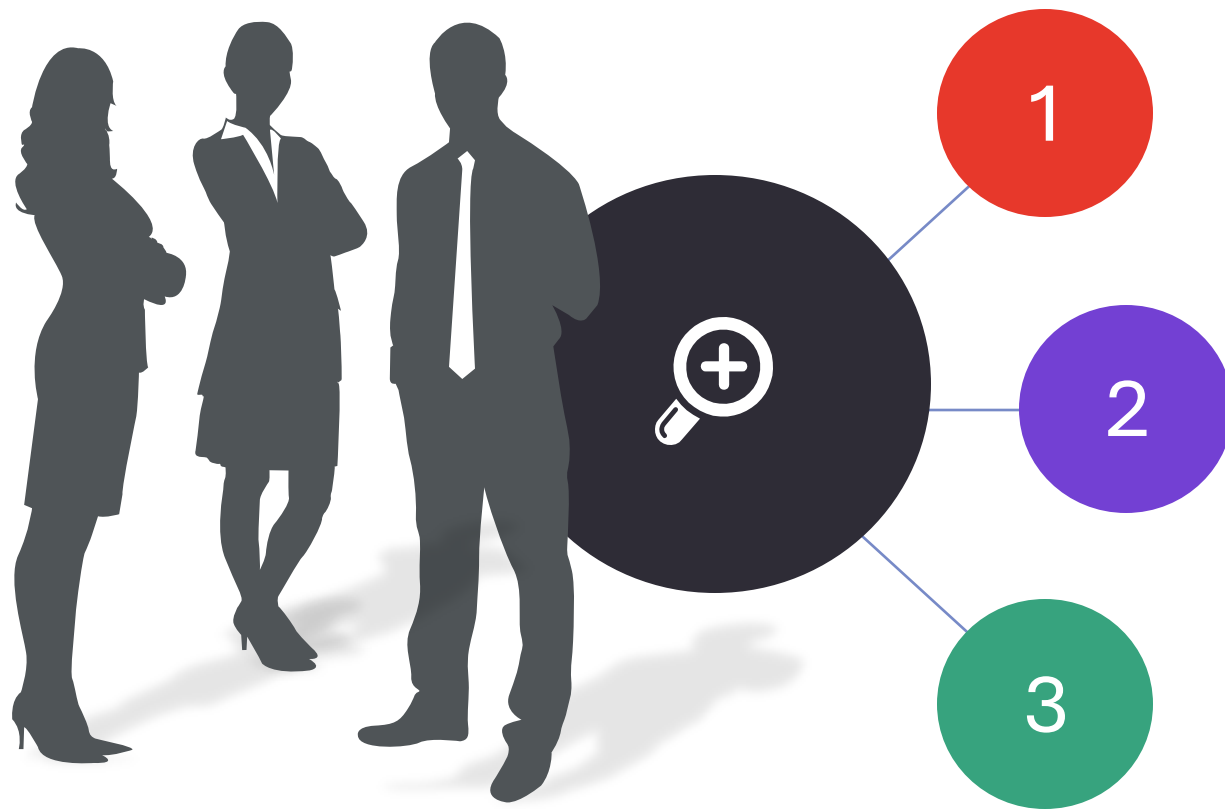








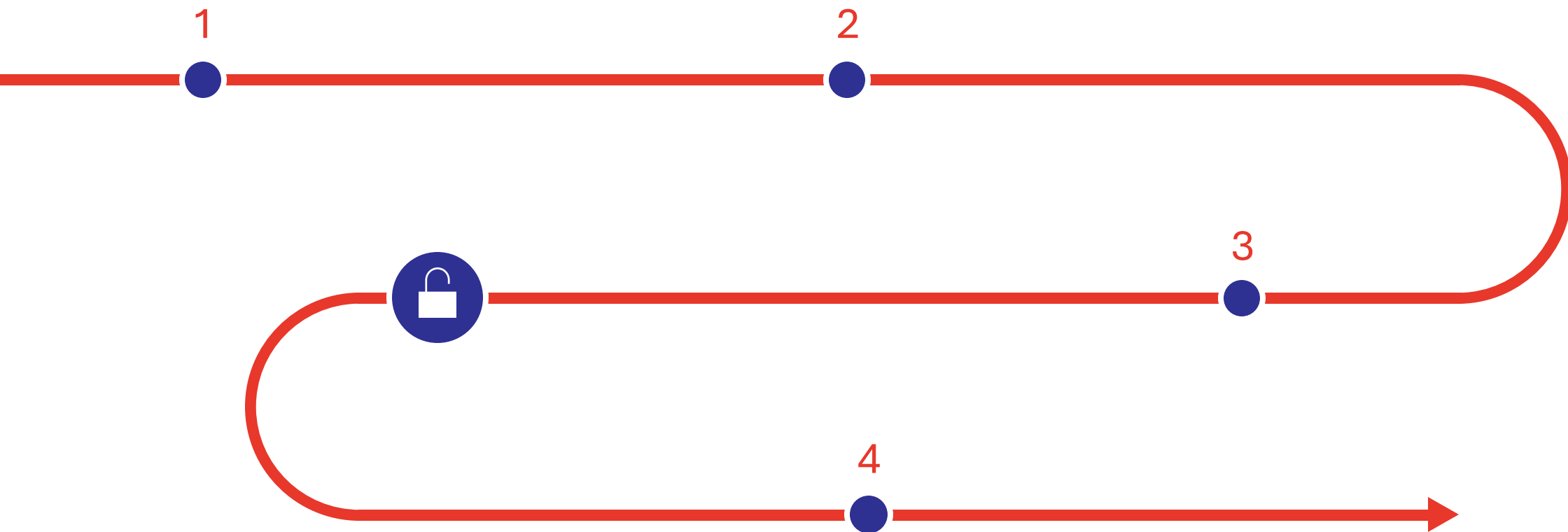






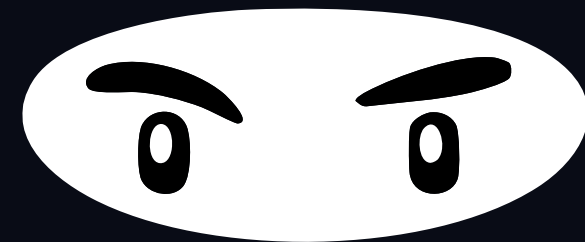




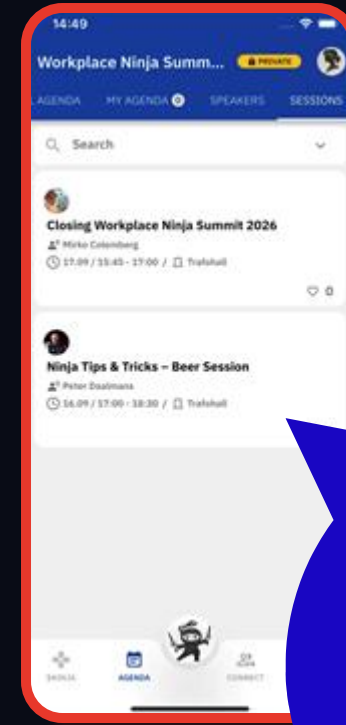
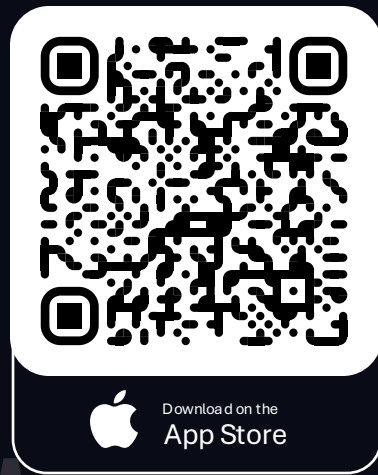
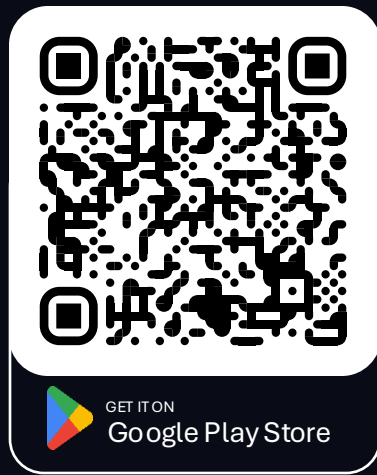


See You
Next Year!

SUMMIT
SUMMIT
SUMMIT
SUMMIT
SUMMIT



Download the app and never miss any updates



We appreciate
your feedback!